

Windows Security Cheat Sheet

⚠ Run every command as Administrator

1 Secure admin credentials

```
Rename-LocalUser -Name "Administrator" -NewName "sysadm01"
Set-LocalUser -Name "sysadm01" -Password (Read-Host -AsSecureString
"New password")
Disable-LocalUser -Name "Guest"
```

2 Take backups of services and important files

```
# Quick folder mirror
robocopy C:\important\path D:\backup\path /MIR

# Full system state backup
wbadmin start backup -backupTarget:D: -include:C: -allCritical -quiet
```

3 Create a backup admin

```
$pw = Read-Host -AsSecureString "Password"
New-LocalUser -Name "backupadmin" -Password $pw
Add-LocalGroupMember -Group "Administrators" -Member "backupadmin"
```

4 Secure user & service passwords

```
Set-LocalUser -Name "<USERNAME>" -Password (Read-Host -AsSecureString
"New password")

# Change the password a service logs on with
sc.exe config <SERVICE_NAME> password= "<NEW_PASSWORD>"
```

5 Audit users and remove / disable unauthorized accounts

```
Get-LocalUser # list accounts
Get-LocalGroupMember -Group "Administrators" # admins
Disable-LocalUser -Name "<USERNAME>" # reversible
Remove-LocalUser -Name "<USERNAME>" # deletes
```

6 Set & enforce a password policy

```
# View local security policy
secedit /export /cfg C:\policy.cfg
notepad C:\policy.cfg

# min length, max age (days), lockout threshold
net accounts /minpwn:14 /maxpwn:60 /lockoutthreshold:5
```

7 Disable vulnerable services (if possible)

```
Get-Service | Where-Object Status -eq 'Running'
Stop-Service -Name <SERVICE_NAME> -Force
Set-Service -Name <SERVICE_NAME> -StartupType Disabled
```

8 Remove unneeded remote access services

```
Get-WindowsOptionalFeature -Online | Where-Object FeatureName -like
"*Telnet*"
Disable-WindowsOptionalFeature -Online -FeatureName TelnetClient

Set-Service -Name RemoteRegistry -StartupType Disabled
Stop-Service -Name RemoteRegistry -Force
```

9 Harden SSH / RDP

```
# Disable RDP entirely if it's not needed
Set-ItemProperty -Path 'HKLM:\System\CurrentControlSet\Control\Terminal
Server' -Name "fDenyTSConnections" -Value 1

# If RDP is needed, require Network Level Authentication
Set-ItemProperty -Path 'HKLM:\System\CurrentControlSet\Control\Terminal
Server\WinStations\RDP-Tcp' -Name "UserAuthentication" -Value 1

# OpenSSH server: edit C:\ProgramData\ssh\sshd_config
# PermitRootLogin no
# PasswordAuthentication no
Restart-Service sshd
```

10 Enable and configure the firewall

```
Set-NetFirewallProfile -Profile Domain,Public,Private -Enabled True
Get-NetFirewallRule -Enabled True | Format-Table
DisplayName,Direction,Action

# Block an unwanted inbound port/service
New-NetFirewallRule -DisplayName "Block Telnet" -Direction Inbound -
Protocol TCP -LocalPort 23 -Action Block

# Remove a rule allowing something you don't want
Remove-NetFirewallRule -DisplayName "<RULE_NAME>"
```

11 Enable logging and monitoring

```
# Enable key auditing categories
auditpol /set /subcategory:"Logon" /success:enable /failure:enable
auditpol /get /category:*

# Turn on PowerShell Script Block Logging
Set-ItemProperty -Path
'HKLM:\SOFTWARE\Policies\Microsoft\Windows\PowerShell\ScriptBlockLoggin
g' -Name "EnableScriptBlockLogging" -Value 1

# Install Sysmon with a config file
.\Sysmon64.exe -accepteula -i config.xml
```

12 Run a scan with Defender

```
Update-MpSignature
Start-MpScan -ScanType QuickScan
Start-MpScan -ScanType FullScan
Get-MpThreatDetection # review anything it already caught
```

13 Harden GPO, Registry, startup & Task Scheduler

```
gpupdate /force

# Review startup entries
Get-ItemProperty 'HKLM:\SOFTWARE\Microsoft\Windows\CurrentVersion\Run'
Get-ItemProperty 'HKCU:\SOFTWARE\Microsoft\Windows\CurrentVersion\Run'
Remove-ItemProperty -Path
'HKLM:\SOFTWARE\Microsoft\Windows\CurrentVersion\Run' -Name "
<ENTRY_NAME>"

# Review and disable suspicious scheduled tasks
Get-ScheduledTask | Where-Object State -eq 'Ready'
Disable-ScheduledTask -TaskName "<TASK_NAME>"
```